Approved AI tools – team guideline (DRAFT)

> **DRAFT for discussion. It is not yet policy.** It must be reviewed and confirmed by our Information Security and Legal teams before anyone relies on it. Where this draft and an official company policy disagree, the official policy wins.

Purpose. Decide, before pasting anything, whether a piece of text may go into a given AI tool. Based on the lab's example table and vendors' published terms (October 2026); terms change, and Security owns the current answer.

The rule in one line

Classify the data first, then pick the tool. If you are not sure of the classification, treat it as the higher one.

Decision table

Data class	Example	Claude Code with organisation key	Consumer chat (personal account)	Enterprise plan chat
Public	Published web page, public product terms	**Allowed.** Public text carries no confidentiality risk, and the key is managed by the organisation.	**Allowed.** Public text is already public; still avoid adding comments about colleagues or clients.	**Allowed.** Same reasoning; the enterprise terms add protection that public data doesn't need.
Internal	Meeting notes without personal data, internal process drafts	**Allowed.** Covered by the organisation's commercial terms, under which API inputs are not used for training by default; confirm the contract with Security.	**Not allowed.** Consumer terms let chats be used for training by default, and the company has no contract, audit trail or deletion control.	**Ask Security.** Usually acceptable, but only once Security confirms our enterprise agreement and workspace settings cover internal data.
Confidential / personal	Customer names, account or order history, employee records	**Ask Security.** Needs a confirmed data-processing agreement, a data-protection impact assessment and the minimum data necessary; redact or use synthetic data wherever possible.	**Not allowed.** No circumstances: personal data in a personal account is a likely data-protection breach and cannot be recalled.	**Ask Security.** Possible only if the agreement, data residency and retention have been approved for this data class and use case.

Always

- Synthetic or redacted data first. `redact_pii.py` helps, but it does **not** catch names or free-text details. Read the text yourself.
- Check the account before you paste: personal and work accounts look identical in the browser.
- Treat every AI answer as a draft. A person checks figures, quotes and anything that will reach a customer.
- Keep the API key out of code, screenshots, chats and Git; `.env` stays local.
- Report anything pasted by mistake to Security straight away. Fast reporting limits the harm.

Never

- Paste customer, employee or bank data into a personal/free account, whatever its privacy toggle says.
- Use a tool that is not on this list for work data without asking Security first.
- Act on an unchecked model answer for anything that moves money, changes records or touches identity.

Owner: the team, pending Security and Legal review. Re-check when a vendor changes its terms, at least every 6 months.